

Отчёт по индивидуальному проекту № 2

Основы информационной безопасности

Луангсуваннавонг Сайпхачан, НКАбд-01-24

Содержание

1	Цель работы	5
2	Задание	6
3	Теоретическое введение	7
4	Выполнение лабораторной работы	9
5	Выводы	17

Список иллюстраций

4.1	Загрузка DVWA	9
4.2	Изменение разрешения доступа к файлу	9
4.3	Проверка содержимого папки	10
4.4	Изменение имени файла	10
4.5	Редактирование файла	10
4.6	Редактирование файла	11
4.7	Запуск MySQL	11
4.8	вход в MySQL	12
4.9	Создание базы данных	12
4.10	Запуск веб-сервера	13
4.11	Переход к настройке веб-сервера	13
4.12	Редактирование файла	14
4.13	Вход на веб-сервер	14
4.14	Страница входа	14
4.15	Страница настройки	15
4.16	Создание/ сброс базы данных	15
4.17	Страница входа	16
4.18	Домашняя страница	16

Список таблиц

1 Цель работы

Приобретение практических навыков по установке DVWA.

2 Задание

Установка DVWA в Kali Linux

3 Теоретическое введение

DVWA (Damn Vulnerable Web Application) — это уязвимое веб-приложение, разработанное на PHP и MySQL. Будучи намеренно небезопасным, оно служит учебной площадкой для отработки распространенных веб-уязвимостей и тестирования инструментов безопасности.

Некоторые из уязвимостей веб приложений, который содержит DVWA:

- Брутфорс: Брутфорс HTTP формы страницы входа - используется для тестирования инструментов по атаке на пароль методом грубой силы и показывает небезопасность слабых паролей.
- Исполнение (внедрение) команд: Выполнение команд уровня операционной системы.
- Межсайтовая подделка запроса (CSRF): Позволяет «атакующему» изменить пароль администратора приложений.
- Внедрение (инклюд) файлов: Позволяет «атакующему» присоединить удалённые/локальные файлы в веб приложение.
- SQL внедрение: Позволяет «атакующему» внедрить SQL выражения в HTTP из поля ввода, DVWA включает слепое и основанное на ошибке SQL внедрение.
- Небезопасная выгрузка файлов: Позволяет «атакующему» выгрузить вредоносные файлы на веб сервер.
- Межсайтовый скриптинг (XSS): «Атакующий» может внедрить свои скрипты в веб приложение/базу данных. DVWA включает отражённую и хранимую XSS.

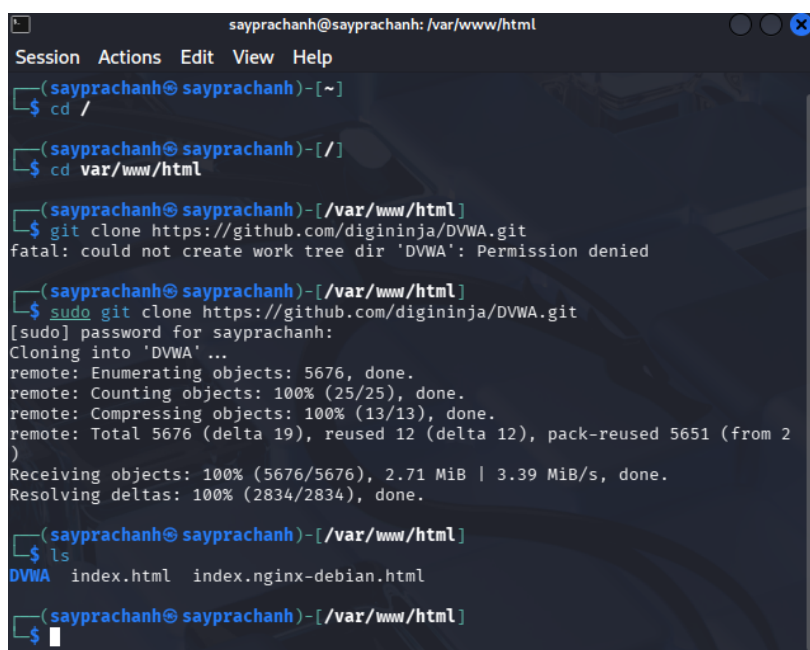
- Пасхальные яйца: раскрытие полных путей, обход аутентификации и некоторые другие.

DVWA имеет четыре уровня безопасности, они меняют уровень безопасности каждого веб приложения в DVWA:

- Невозможный — этот уровень должен быть безопасным от всех уязвимостей. Он используется для сравнения уязвимого исходного кода с безопасным исходным кодом.
- Высокий — это расширение среднего уровня сложности, со смесью более сложных или альтернативных плохих практик в попытке обезопасить код. Уязвимости не позволяют такой простор эксплуатации как на других уровнях.
- Средний — этот уровень безопасности предназначен главным образом для того, чтобы дать пользователю пример плохих практик безопасности, где разработчик попытался сделать приложение безопасным, но потерпел неудачу.
- Низкий — этот уровень безопасности совершенно уязвим и совсем не имеет защиты. Его предназначение быть примером среди уязвимых веб приложений, примером плохих практик программирования и служить платформой обучения базовым техникам эксплуатации.

4 Выполнение лабораторной работы

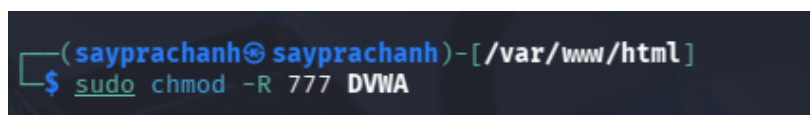
Сначала я перехожу в папку веб-сервера в корневом каталоге и загружаю DVWA через Github. (рис. 4.1)



```
sayprachanh@sayprachanh: /var/www/html
Session Actions Edit View Help
(sayprachanh@sayprachanh)-[~]
$ cd /
(sayprachanh@sayprachanh)-[/]
$ cd var/www/html
(sayprachanh@sayprachanh)-[/var/www/html]
$ git clone https://github.com/digininja/DVWA.git
fatal: could not create work tree dir 'DVWA': Permission denied
(sayprachanh@sayprachanh)-[/var/www/html]
$ sudo git clone https://github.com/digininja/DVWA.git
[sudo] password for sayprachanh:
Cloning into 'DVWA' ...
remote: Enumerating objects: 5676, done.
remote: Counting objects: 100% (25/25), done.
remote: Compressing objects: 100% (13/13), done.
remote: Total 5676 (delta 19), reused 12 (delta 12), pack-reused 5651 (from 2)
Receiving objects: 100% (5676/5676), 2.71 MiB | 3.39 MiB/s, done.
Resolving deltas: 100% (2834/2834), done.
(sayprachanh@sayprachanh)-[/var/www/html]
$ ls
DVWA  index.html  index.nginx-debian.html
(sayprachanh@sayprachanh)-[/var/www/html]
$
```

Рисунок 4.1: Загрузка DVWA

Я изменяю права доступа к папке на 777.(рис. 4.2)



```
(sayprachanh@sayprachanh)-[/var/www/html]
$ sudo chmod -R 777 DVWA
```

Рисунок 4.2: Изменение разрешения доступа к файлу

Затем я перехожу в папку DVWA, проверяю содержимое папки, нахожу и

проверяю папку „config“.(рис. 4.3)

```
(sayprachanh@sayprachanh)-[/var/www/html]
$ cd DVWA

(sayprachanh@sayprachanh)-[/var/www/html/DVWA]
$ ls
about.php      dvwa          phpinfo.php   README.ko.md  README.zh.md
CHANGELOG.md   external      php.ini       README.md     robots.txt
compose.yml    favicon.ico   README.ar.md  README.pl.md  SECURITY.md
config         hackable     README.es.md  README.pt.md  security.php
COPYING.txt    index.php    README.fa.md  README.ru.md  security.txt
database       instructions.php README.fr.md  README.tr.md  setup.php
Dockerfile     login.php    README.id.md  README.uk.md  tests
docs           logout.php   README.it.md  README.vi.md  vulnerabilities
```

```
(sayprachanh@sayprachanh)-[/var/www/html/DVWA]
$ cd config

(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$ ls
config.inc.php.dist
```

Рисунок 4.3: Проверка содержимого папки

Я переименовываю файл config.inc.php.dist в config.inc.php, затем открываю файл для редактирования с помощью текстового редактора. В файле config.inc.php я изменяю информацию о базе данных, меняю пароль на „password“ и пользователя на „admin“, затем сохраняю и выхожу из файла.(рис. 4.4)(рис. 4.5)(рис. 4.6)

```
(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$ sudo mv config.inc.php.dist config.inc.php

(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$ ls
config.inc.php

(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$
```

Рисунок 4.4: Изменение имени файла

```
(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$ sudo vim config.inc.php
```

Рисунок 4.5: Редактирование файла

```
# Database variables
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED
# during setup.
# Please use a database dedicated to DVWA.
#
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA user.
# See README.md for more information on this.
$_DVWA = array();
$_DVWA[ 'db_server' ] = getenv('DB_SERVER') ? : '127.0.0.1';
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ? : 'dvwa';
$_DVWA[ 'db_user' ] = getenv('DB_USER') ? : 'admin';
$_DVWA[ 'db_password' ] = getenv('DB_PASSWORD') ? : 'password';
$_DVWA[ 'db_port' ] = getenv('DB_PORT') ? : '3306';

# ReCAPTCHA settings
```

Рисунок 4.6: Редактирование файла

Затем с помощью команды `systemctl` я запускаю службу MySQL, чтобы создать новую базу данных. Поскольку MySQL уже установлен по умолчанию, я могу запустить его сразу, затем проверяю статус процесса.(рис. 4.7)

```
(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$ sudo systemctl start mysql

(sayprachanh@sayprachanh)-[/var/www/html/DVWA/config]
$ sudo systemctl status mysql
● mariadb.service - MariaDB 11.8.3 database server
   Loaded: loaded (/usr/lib/systemd/system/mariadb.service; disabled;
   Active: active (running) since Fri 2026-03-13 08:57:41 MSK; 8s ago
   Invocation: 96f7f50900864385abc1f086ce8a57e7
   Docs: man:mariadb(8)
        https://mariadb.com/kb/en/library/systemd/
   Process: 8676 ExecStartPre=/usr/bin/install -m 755 -o mysql -g root
   Process: 8678 ExecStartPre=/bin/sh -c [ ! -e /usr/bin/galera_recove
   Process: 8752 ExecStartPost=/bin/rm -f /run/mysqld/wsrep-start-posi
   Process: 8754 ExecStartPost=/etc/mysql/debian-start (code=exited, s
   Main PID: 8730 (mariadb)
   Status: "Taking your SQL requests now..."
   Tasks: 14 (limit: 56956)
   Memory: 156.5M (peak: 161.3M)
   CPU: 1.690s
   CGroup: /system.slice/mariadb.service
```

Рисунок 4.7: Запуск MySQL

Я вхожу в MySQL как root, сервис использует приглашение „MariaDB“, затем начинаю создавать базу данных для нового пользователя в нем.(рис. 4.8)

```
(sayprachanh@sayprachanh)~[/var/www/html/DVWA/config]
$ sudo su
(root@sayprachanh)~[/var/www/html/DVWA/config]
$ mysql -u root -p
Enter password:
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.3-MariaDB-1+b1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]>
```

Рисунок 4.8: вход в MySQL

Я начинаю с создания новой базы данных „dvwa“, с именем и паролем в соответствии с файлом config.inc.php, а также предоставляю пользователю привилегии для работы с этой базой данных. (Примечание: имя базы данных, пользователя и пароль должны быть идентичны информации в файле config.inc.php)(рис. 4.9)

```
(root@sayprachanh)~[/etc/php/8.4/apache2]
$ mysql -u root -p
Enter password:
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 48
Server version: 11.8.3-MariaDB-1+b1 from Debian -- Please help get to 10k stars at https://github.com/MariaDB/Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create database dvwa;
ERROR 1007 (HY000): Can't create database 'dvwa'; database exists
MariaDB [(none)]> drop database dvwa;
Query OK, 0 rows affected (0.011 sec)

MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.000 sec)

MariaDB [(none)]> create user 'admin'@'127.0.0.1' identified by 'password';
Query OK, 0 rows affected (0.002 sec)

MariaDB [(none)]> grant all privileges on dvwa.* to 'admin'@'127.0.0.1';
Query OK, 0 rows affected (0.002 sec)

MariaDB [(none)]> exit
Bye
```

Рисунок 4.9: Создание базы данных

После этого я выхожу из службы MySQL и запускаю веб-сервер Apache, а затем проверяю статус веб-сервера.(рис. 4.10)

```
(root@sayprachanh)-[/var/www/html/DVWA/config]
# systemctl start apache2

(root@sayprachanh)-[/var/www/html/DVWA/config]
# systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-03-13 09:04:40 MSK; 5s ago
     Invocation: 0e6a4201c2624a06bb3c3cb7cd684d97
       Docs: https://httpd.apache.org/docs/2.4/
    Process: 12279 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
   Main PID: 12295 (apache2)
      Tasks: 6 (limit: 6629)
   Memory: 25.5M (peak: 25.5M)
      CPU: 206ms
   CGroup: /system.slice/apache2.service
           └─12295 /usr/sbin/apache2 -k start
             └─12298 /usr/sbin/apache2 -k start
               └─12299 /usr/sbin/apache2 -k start
                 └─12300 /usr/sbin/apache2 -k start
                   └─12301 /usr/sbin/apache2 -k start
                     └─12302 /usr/sbin/apache2 -k start

Mar 13 09:04:40 sayprachanh systemd[1]: Starting apache2.service - The Apache HTTP Server...
Mar 13 09:04:40 sayprachanh systemd[1]: Started apache2.service - The Apache HTTP Server.
```

Рисунок 4.10: Запуск веб-сервера

Далее необходимо выполнить некоторые настройки файла `php.ini` в папке `Apache2`, поэтому я перехожу в эту папку и открываю его в текстовом редакторе.(рис. 4.11)

```
(root@sayprachanh)-[/var/www/html/DVWA/config]
# cd /etc/php

(root@sayprachanh)-[/etc/php]
# ls
8.4

(root@sayprachanh)-[/etc/php]
# cd 8.4

(root@sayprachanh)-[/etc/php/8.4]
# cd apache2

(root@sayprachanh)-[/etc/php/8.4/apache2]
# ls
conf.d  php.ini

(root@sayprachanh)-[/etc/php/8.4/apache2]
# vim php.ini
```

Рисунок 4.11: Переход к настройке веб-сервера

В файле я ищу конкретное ключевое слово „`foren`“, затем изменяю настройку `allow_url_include` с „`Off`“ на „`On`“, так как оба параметра файла `allow_url_foren` и `allow_url_include` должны быть изменены на „`On`“. После этого я сохраняю и выхожу из файла, и снова перезапускаю веб-сервер.(рис. 4.12)

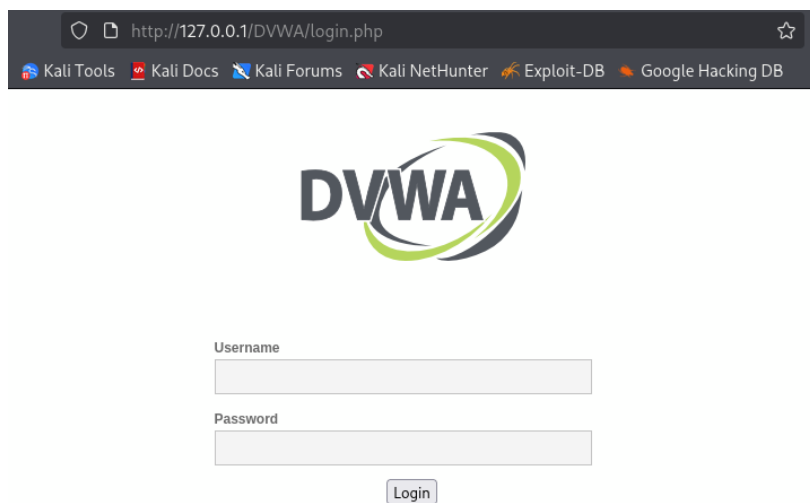
```
#####  
; Fopen wrappers ;  
#####  
  
; Whether to allow the treatment of URLs (like http:// or ftp://) as files.  
; https://php.net/allow-url-fopen  
allow_url_fopen = On  
  
; Whether to allow include/require to open URLs (like https:// or ftp://) as files.  
; https://php.net/allow-url-include  
allow_url_include = Off
```

Рисунок 4.12: Редактирование файла

Я открываю браузер и ввожу 127.0.0.1/DVWA. Так как у нас уже есть база данных, а также настроен веб-сервер, мы можем войти в веб-приложение через этот URL. Затем я просто ввожу имя и пароль, которые установил ранее, и попадаю на страницу настройки(рис. 4.13)(рис. 4.14)(рис. 4.15).

```
(root@sayprachanh)-[/etc/php/8.4/apache2]  
# systemctl restart apache2
```

Рисунок 4.13: Вход на веб-сервер



http://127.0.0.1/DVWA/login.php

Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

DVWA

Username

Password

Login

Рисунок 4.14: Страница входа

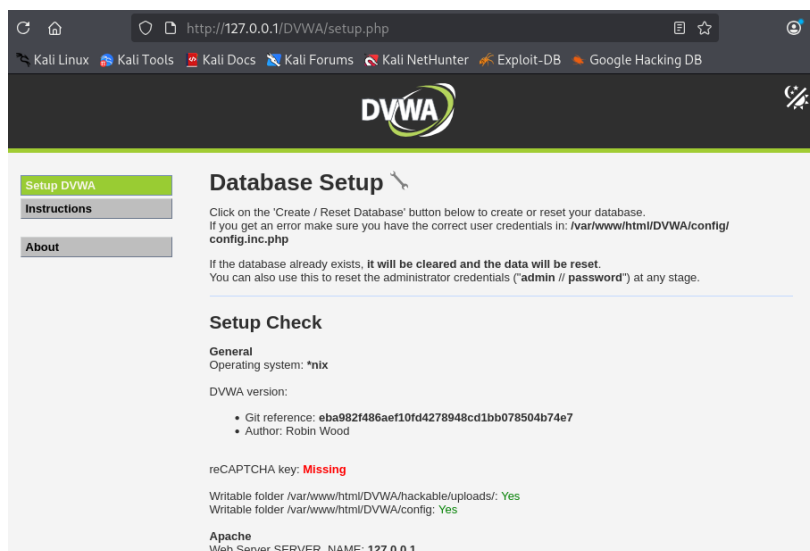


Рисунок 4.15: Страница настройки

Я прокручиваю страницу вниз и нажимаю кнопку „Create / Reset Database“, которая снова запросит имя и пароль.(рис. 4.16)(рис. 4.17)

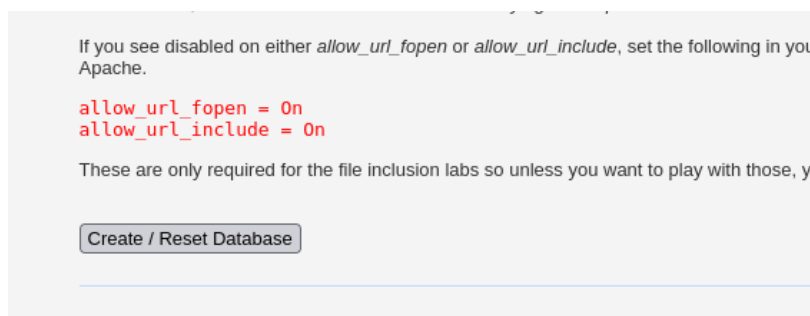
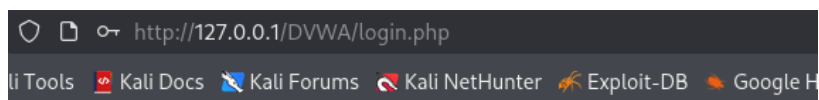


Рисунок 4.16: Создание/ сброс базы данных



Username

Password

Login

Рисунок 4.17: Страница входа

Затем я попадаю на домашнюю страницу веб-приложения и завершаю установку.(рис. 4.18)

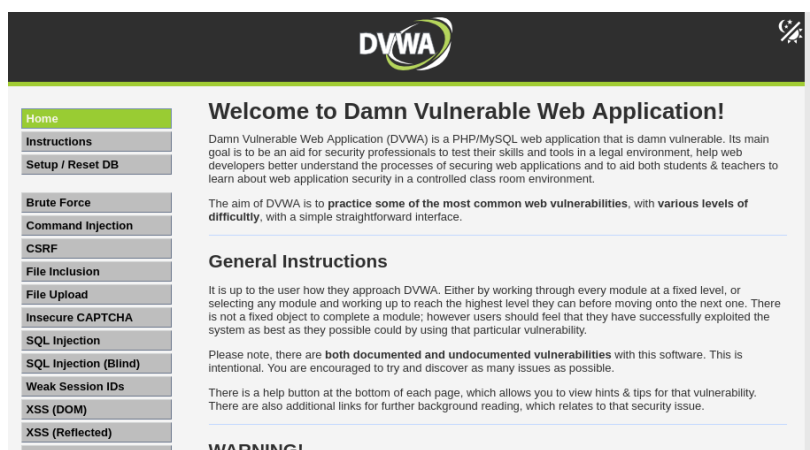


Рисунок 4.18: Домашняя страница

5 Выводы

Я приобрел практические навыки по установке DVWA